

Guía metodológica de la encuesta sobre KEV, vulnerabilidades, pentesting, SIEM y capacitación

1. Objetivo general

Esta guía describe cómo diseñar, aplicar y analizar una encuesta de madurez en ciberseguridad centrada en:

- Gestión de vulnerabilidades y, en particular, de las Known Exploited Vulnerabilities (KEV).
- Pruebas de penetración y ejercicios de Red/Purple Team.
- Monitorización y gestión de eventos de seguridad (SIEM/SOC).
- Capacitación y cultura de seguridad de los empleados.

El resultado esperado es un **Índice Global de Madurez (IGM)** y una serie de subíndices que permitan comparar organizaciones, sectores y periodos, así como apoyar decisiones de inversión (incluido el análisis de ROI).

2. Alcance y población objetivo

2.1 Tipo de organizaciones

La encuesta está pensada para ser aplicada en:

- Organizaciones públicas y privadas de cualquier tamaño.
- Especialmente útil en:
- Operadores de servicios esenciales o importantes (NIS2).
- Entidades sujetas al Esquema Nacional de Seguridad (ENS).
- Sectores con fuerte dependencia digital (financiero, sanitario, industrial, TIC, etc.).

2.2 Perfil de personas encuestadas

Se recomienda que respondan, de forma conjunta o coordinada:

- CISO o responsable de seguridad de la información.
- Responsables de infraestructura/TI.
- Responsables de SOC/SIEM.
- Responsables de formación y concienciación.
- Cuando proceda, responsables de continuidad de negocio y gestión de riesgos.

La encuesta puede rellenarse de forma **colaborativa** (por ejemplo, en una sesión de trabajo interna) para fomentar una visión compartida.

3. Diseño del cuestionario

3.1 Bloques temáticos

El modelo de encuesta (`encuesta-modo.md`) se estructura en los siguientes bloques:

1. PERF – Perfil de la organización.
2. GOV – Gobierno y estrategia de vulnerabilidades.
3. VUL – Gestión operativa de vulnerabilidades y KEV.
4. PEN – Pruebas de penetración y ejercicios.
5. SIEM – Monitorización, SIEM y detección.
6. AWR – Capacitación y cultura de seguridad.
7. MET – Métricas, indicadores y ROI.
8. IMP – Planes de mejora y obstáculos.

3.2 Identificadores de preguntas

Cada pregunta tiene un identificador único (por ejemplo, «GOV-01», «VUL-03»).

Estos identificadores se utilizan en:

- El propio cuestionario.
- El libro de Excel para el cálculo de IGM y ROI.
- El mapeo normativo.

Se recomienda **no modificarlos** para mantener la compatibilidad entre componentes.

3.3 Tipos de preguntas y escalas

Se emplean principalmente:

- Preguntas de opción única con 3–5 alternativas ordenadas de menor a mayor madurez.
- Preguntas tipo Likert (por ejemplo, de «Totalmente en desacuerdo» a «Totalmente de acuerdo»).
- Preguntas abiertas acotadas (para detallar principales obstáculos, iniciativas, etc.), que no intervienen directamente en el cálculo del IGM pero enriquecen la interpretación.

Para cada pregunta cerrada, se definirá una **codificación numérica** (por ejemplo, 1–4), documentada en el libro Excel.

4. Procedimiento de aplicación

4.1 Modalidades posibles

- Autorrelleno online: envío de un enlace a un formulario (por ejemplo, herramienta de encuestas, formulario corporativo, etc.).
- Entrevista guiada: un entrevistador realiza las preguntas y registra las respuestas.
- Taller colaborativo: sesión de trabajo en la que los responsables debaten y acuerdan las respuestas.

La modalidad puede combinarse, respetando siempre la **consistencia** en la interpretación de las preguntas.

4.2 Recomendaciones prácticas

9. Comunicar claramente el objetivo de la encuesta (mejora, no auditoría punitiva).
10. Estimar el tiempo de respuesta (por ejemplo, 45–60 minutos) y respetarlo en la práctica.
11. Evitar periodos de máxima carga operativa (cierres, migraciones críticas, etc.).
12. Ofrecer un punto de contacto para dudas sobre el significado de las preguntas.

4.3 Periodicidad recomendada

- Primera aplicación: establecimiento de línea base.
- Repetición: cada 12–24 meses, o tras cambios disruptivos (grandes proyectos de transformación, reorganizaciones, incidentes graves).

5. Tratamiento de datos

5.1 Limpieza y validación

Antes de calcular indicadores:

- Comprobar que todas las preguntas obligatorias tienen respuesta.
- Revisar valores atípicos o inconsistentes (por ejemplo, combinaciones imposible de madurez extrema y ausencia total de procesos).
- Documentar cualquier corrección o imputación efectuada.

5.2 Codificación

- Asignar valores numéricos a las opciones de respuesta según la escala definida.
- En preguntas con opciones que representen situaciones claramente negativas, pero muy informativas, usar valores bajos (1–2) sin miedo: el propósito es discriminar niveles de madurez.

5.3 Agregación por dimensiones

- Calcular, para cada organización, la media ponderada de las respuestas de cada bloque (GOV, VUL, etc.).
- Normalizar, si se desea, a una escala común (por ejemplo, 0–100) para facilitar la comunicación:

$$\text{Índice_normalizado} = (\text{Media_respuestas} - \text{Valor_Min}) / (\text{Valor_Max} - \text{Valor_Min}) * 100$$

6. Cálculo del Índice Global de Madurez (IGM)

6.1 Lógica general

El IGM se define como una **media ponderada** de los subíndices de bloque:

$$\text{IGM} = \sum (\text{Subíndice_bloque} \times \text{Peso_bloque})$$

Los pesos por bloque pueden ajustarse según el contexto, pero una propuesta razonable es:

- GOV: 15 %
- VUL: 25 %
- PEN: 15 %
- SIEM: 20 %
- AWR: 15 %
- MET: 10 %

6.2 Subíndices por bloque

Cada subíndice se calcula como la media ponderada de las preguntas de ese bloque, normalizada a 0–100. La hoja Ponderaciones del Excel define el peso de cada pregunta dentro de su bloque.

6.3 Niveles cualitativos

Sobre la escala 0–100 se pueden definir niveles cualitativos, por ejemplo:

- 0–20: Nivel 1 – Inicial.
- 21–40: Nivel 2 – Básico.
- 41–60: Nivel 3 – Definido.
- 61–80: Nivel 4 – Gestionado.
- 81–100: Nivel 5 – Optimizado.

Estos umbrales pueden adaptarse, siempre que se documenten claramente.

7. Estimación del ROI de iniciativas de mejora

7.1 Enfoque conceptual

El análisis de ROI se apoya en una comparación entre:

- Situación actual: pérdida económica esperada asociada a incidentes donde las vulnerabilidades (especialmente KEV) juegan un papel clave.
- Situación prevista tras la mejora: pérdida esperada reducida, gracias a controles adicionales, mejor gestión de vulnerabilidades, mayor capacidad de detección, etc.

El ROI clásico se expresa como:

$$\text{ROI} = (\text{Ahorro_anual} - \text{Coste_anual_iniciativa}) / \text{Coste_anual_iniciativa}$$

donde:

- $\text{Ahorro_anual} = \text{Pérdida_Esperada_Actual} - \text{Pérdida_Esperada_Prevista}$.

7.2 Uso de la hoja «ROI»

La plantilla `plantilla-igm-roi.md` propone una estructura con columnas para:

- Descripción de la iniciativa.
- Dimensión a la que contribuye.
- Coste anual estimado.
- Pérdida esperada actual y prevista.
- Ahorro y ROI.

Las cifras deben aportarse a partir de análisis propios de riesgo, incidentes históricos, benchmarks sectoriales o juicio experto.

7.3 Advertencias

- El ROI en ciberseguridad nunca es puramente financiero: hay componentes de cumplimiento, reputación y resiliencia difíciles de monetizar.
- Es preferible ser prudente y transparente en las hipótesis que inflar beneficios esperados.

8. Interpretación y comunicación de resultados

8.1 Internamente

- Compartir resultados agregados con las áreas implicadas.
- Enfocar las discusiones en prioridades y planes de acción, no en «culpables».
- Usar gráficos y visualizaciones (radar de madurez, barras por bloque, etc.) para facilitar la comprensión.

8.2 Hacia la alta dirección

- Destilar los resultados en pocos mensajes clave apoyados en el IGM y algunos subíndices.
- Acompañar siempre los datos de recomendaciones concretas.
- Traducir el lenguaje técnico a impacto en negocio (riesgo evitado, cumplimiento regulatorio, continuidad de operaciones).

9. Limitaciones y buenas prácticas éticas

- La encuesta es un autodiagnóstico: puede haber sesgos de percepción u optimismo/pesimismo excesivo.
- No debe utilizarse como único criterio para comparaciones públicas entre organizaciones.
- Los resultados deben tratarse con confidencialidad y compartirse de forma responsable.

Como toda herramienta, su valor reside en cómo se utiliza. Aplicada con rigor y con la mentalidad adecuada, esta encuesta puede convertirse en una aliada para madurar la ciberseguridad de forma medible, razonada y, por qué no, algo más amena.